Register Vulnerability Testing

Educational Bug Bounty Series • Authorized Security Research Only

■ Registration Vulnerability Testing

Contributed by Cyber_Spy.404 | Educational Bug Bounty Series

Scope: *Use only accounts you control and authorized test environments. Do not manipulate real users' accounts or exploit registration flaws on third-party systems.*

■ Executive Summary

Registration weaknesses can allow duplicate-account confusion, unsafe profile paths, weak password policies, or incorrect verification behavior. The supplied one-page checklist lists duplicate registration with case variations, missing name/password validation, absent rate limits, XSS in registration fields, weak email verification, disposable email acceptance, HTTP registration forms, weak passwords, recovery issues, and path overwrite concerns.

■ Core Testing Methodology

1. Create a test account with an email address you control and record expected behavior.
2. Check whether registration prevents duplicate accounts using the same email, including case normalization.
3. Verify username and password fields have clear required-field, length, and format validation.
4. Check whether repeated sign-up attempts are rate-limited.
5. Use harmless markers in username/email fields to verify output encoding; do not use data-exfiltration payloads.
6. Confirm email verification requires a server-validated, single-use token and cannot be bypassed by changing client-side responses.
7. Verify disposable-email policy is explicit and consistently enforced if the service has such a policy.
8. Confirm registration pages and submissions use HTTPS.
9. Review password policy, password reuse controls where applicable, and recovery flows.
10. Check whether profile routes safely handle reserved names and cannot overwrite system paths.
11. Document the expected policy, observed behavior, and minimal redacted evidence.

■ High-Value Bug Bounty Tips & Edge Cases

- **Case normalization:** The source suggests registering the same email with case variations. Email canonicalization must be consistent and must not create ambiguous identities.
- **Long inputs:** The source notes long password values leading to a possible server error. Validation should return a controlled client error rather than HTTP 500.
- **Rate limits:** Registration should have abuse controls appropriate to the product and threat model.
- **XSS:** The source notes username/email reflection; test with a harmless marker and inspect encoding.
- **Email verification:** The checklist mentions response/status manipulation. Client-side response changes must never establish verification; only server-side token validation should.
- **Transport security:** Registration should not submit credentials or personal data over plain HTTP.
- **Weak passwords:** The source suggests checking simple passwords and password-recovery behavior. Do not test credentials against other users.
- **Path overwrite:** The source mentions reserved system filenames/profile paths, but does not give a complete scenario. Treat this as a review item, not a proven exploit.

■■ Educational Checklists & Payloads

```
Target: [Your-Domain]
Test account: [Controlled-Test-Email]
Duplicate registration blocked: [Yes/No]
Case normalization consistent: [Yes/No]
Long input handled safely: [Yes/No]
Registration rate limit present: [Yes/No]
Verification token single-use: [Yes/No]
HTTPS enforced: [Yes/No]
Evidence: [Redacted]
```

Safe output-encoding marker:

```
registration-test-[UNIQUE-ID]
```

- [ ] Required fields and length limits are enforced server-side.
- [ ] Duplicate identities are handled consistently.
- [ ] User-controlled values are output-encoded.
- [ ] Verification is server-side and token-based.
- [ ] Passwords are stored using a modern password-hashing function.
- [ ] Rate limits and abuse detection are enabled.
- [ ] Registration uses HTTPS.

■■ Mitigation & Remediation

Normalize identity values consistently, enforce server-side validation and rate limits, use secure password hashing and password policy, require single-use expiring verification tokens, encode output by context, enforce HTTPS, and protect profile routes from reserved-name/path conflicts.

■ Source Notes

Based on the supplied one-page *register vuln.pdf*. It lists duplicate registration, long-input errors, no signup rate limit, XSS in username/email, verification response/status manipulation, disposable email, HTTP registration, weak passwords, recovery-link behavior, and path overwrite. The source does not provide a full reproduction for every item.

Educational use only. Test only accounts you control.

Educational use only. Test only systems you own or are explicitly authorized to assess. Confirm redistribution rights for source-derived material.